Loja Pronta Prime — Security and Data Protection Overview

Prepared for the Shopee Open Platform review team. **Unsigned draft for representative review.**

Execution status, 22 October 2026: the partner profile is rejected and its registered company details do not match the supplied MSL documents. Registration was stopped under the owner's runbook. No new Loja Pronta Prime app has been created or submitted. The reviewer account signs in successfully, but its connection page shows a preparation notice without an authorization button. This document is not evidence of new-app approval or sandbox testing.

Implementation descriptions below refer to existing repository code. Infrastructure checks reported for 22 October come from the preparatory notes and were not rerun in this execution. Statements marked as policy are commitments; they are not evidence of completed configuration.

Item	Value
Company (legal name)	Mentalidade Sem Limite Ltda (trade name: MSL)
CNPJ	46.419.797/0001-67
Registered address	Alameda Rio Negro, 503, Sala 2020, Alphaville, Barueri/SP, 06454-000, Brazil
Legal representative	Guilherme Mendes Flauzino, Administrator
Open Platform account type	Third-party Partner Platform (ISV), Brazil
App name	Loja Pronta Prime
Live product URL	https://lojaprontaprime.com/
Authorization callback	https://lojaprontaprime.com/api/shopee/callback
Security Officer (DPP §4.3)	Guilherme Mendes Flauzino, Administrator — +55 (37) 8805-2023
Security contact for Shopee	Guilherme Mendes Flauzino — +55 (37) 8805-2023 — or the e-mail of this Open Platform account (Mon–Fri, 09:00–18:00 BRT)
Document date	22 October 2026

1. What the application does

Loja Pronta Prime is a members area for beginner sellers in Brazil. It teaches them how to open and run a Shopee shop. The intended integration works like this: after the seller authorizes her own shop, the platform reads her products and their performance (views, clicks) and suggests which product line to keep investing in. With the seller's action, it can also help create or update her own listings. The existing code includes authorization and API resource helpers, but the new app has not been provisioned. Listing publication and supplier import must not be represented as verified live features.

Each seller only ever sees and manages the shop she authorized herself. There is no shared shop and no access to other sellers' data.

The service does not sell accounts, does not extract listings to enable transactions outside Shopee, and does not scrape Shopee. All data comes from the official Open API with the seller's authorization, in line with the Platform Partner Rules.

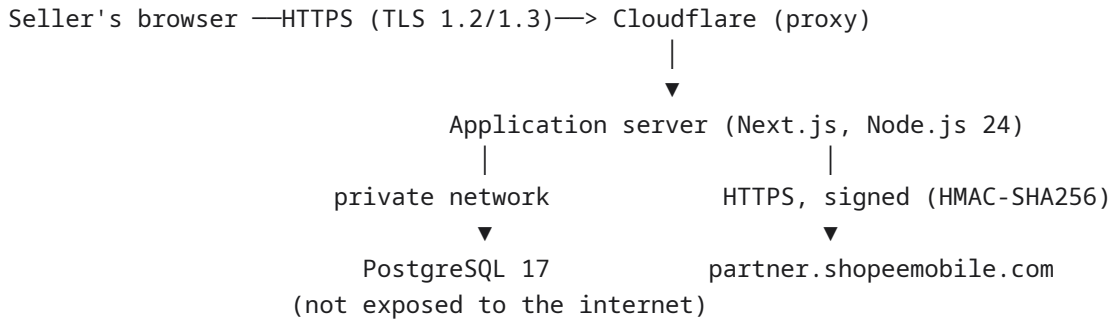
2. Intended Shopee access scope

The app does not request buyer personal data (PII). It does not call order, return, logistics-tracking or chat APIs. The PII Necessity Declaration must remain **OFF** when submitted.

Open API endpoint	Purpose
`v2.auth.token.get`, `v2.auth.access_token.get`	Seller authorization and token refresh
`v2.shop.get_shop_info`, `v2.shop.get_profile`	Confirm the authorized shop (region/status)
`v2.shop.update_profile`	Update the seller's own shop profile
`v2.product.get_item_list`, `get_item_base_info`	List the seller's own products
`v2.product.get_item_extra_info`	Product views and clicks (performance)
`v2.product.get_category`, `get_attributes`, `get_brand_list`	Fill in a listing correctly
`v2.product.add_item`, `update_item`, `init_tier_variation`, `get_model_list`	Create/update the seller's own listings
`v2.media_space.upload_image`	Upload the seller's listing photos
`v2.logistics.get_channel_list`	Pick the shipping channel for a listing

The authorization implementation stores the `shop_id`, encrypted access and refresh tokens, and expiry dates. Product metrics are part of the intended recommendation workflow; their collection through the new app has not been validated. No buyer name, phone, email or address is ever received or stored.

3. Architecture and data flow



- Hosting: virtual private server at Contabo (New Jersey, United States), managed with Coolify. Cloudflare sits in front of the site as proxy and TLS edge.
- Database: PostgreSQL 17 on the private Docker network of the same server. The database port is not reachable from the internet (checked from outside on 22 October 2026).
- Data location: seller-level data (shop ID, encrypted tokens, product metrics) is stored on this server. No buyer personal data is stored anywhere.
- Files (logos, videos): private S3 bucket, accessed only by the server.
- Outgoing calls to Shopee leave from a fixed server IP, declared in the App IP whitelist: `147.93.2.171`.
- "Other IT Assets": the database runs on the same server (`147.93.2.171`). There are no other servers that process Shopee data.

4. Authorization flow (OAuth)

- Only a logged-in seller with access to the product can start the authorization. Limited to three attempts per minute per account.
- A random 32-byte `state` is created for each attempt and stored only as a hash, bound to the user, the session and the app, valid for 10 minutes. A new attempt invalidates the old one.
- The callback checks session, `state`, single-use code and `shop_id`. Duplicate parameters and main accounts with several shops are refused. The `state` is consumed atomically before the code is exchanged, so a code cannot be replayed.
- The callback response has `Cache-Control: no-store` and `Referrer-Policy: no-referrer`, so the code never leaks through cache or the Referer header. Codes and tokens must not be written to logs or persistent browser storage. Authorization codes necessarily arrive in the callback URL; manual mode passes that URL through a server action without adding it to the local page URL. Signed resource requests may include tokens in the server-to-Shopee API URL; those URLs must not be logged.
- A shop can be linked to only one account. Disconnecting deletes the tokens immediately.

5. Protection of secrets and tokens

- Access and refresh tokens are encrypted at rest with **AES-256-GCM**. The owner, shop, app and environment are bound as authenticated data, so a token copied to another record cannot be decrypted.
- Partner Key and encryption key live only in server runtime variables. They are never in the source code, the repository, the browser bundle or logs.
- Every Open API request is signed with HMAC-SHA256, has a 10-second timeout, does not follow redirects and does not automatically retry single-use codes.
- Token refresh is serialized per account to avoid two refreshes racing each other.
- Tokens are never sent to the browser.

6. Application security

- **Authentication:** email and password (minimum 8 characters), passwords hashed with salted scrypt (Better Auth). Login and sensitive actions are rate-limited. Changing the initial password ends every other session in the same transaction.
- **Sessions:** HTTP-only, Secure, SameSite cookies with a server-side session record.

- **Access control (least privilege):** roles separate students from administrators. Every mutation runs on the server (Server Actions) and checks the session and ownership before touching data. A seller can only read and change her own shop connection.
- **Transport:** HTTPS only. Minimum TLS version 1.2 at the edge (TLS 1.0 and 1.1 disabled), TLS 1.3 enabled, HSTS `max-age=63072000; includeSubDomains`. SSL Labs grade: **A+** (tested on 22 October 2026).
- **Security headers:** `X-Frame-Options: DENY`, `Content-Security-Policy` with `frame-ancestors 'none'; object-src 'none'; base-uri 'self'; form-action 'self'`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`, restrictive `Permissions-Policy`.
- **Input validation:** request bodies are size-limited while being read; URLs and webhook payloads are validated; output is escaped by React.
- **Server-only code:** the build blocks server modules (database, keys) from being imported by browser code.
- **Secure development:** every change goes through a pull request with type checking, lint and automated tests (including tests for expired/replayed state, wrong owner/session, token encryption and concurrent refresh). Development and test environments use separate databases and Shopee sandbox credentials; no production data is used outside production (DPP §6.2).
- **Internal security reviews:** code-level security reviews were done on 6 and 17 October 2026, covering authentication, permissions, uploads, webhooks and the Shopee flow. Findings were fixed and documented.

7. Logging and monitoring (DPP §4.7)

- Authentication failures, authorization attempts and errors are logged without personal data, tokens or codes.
- The hosting platform checks `/api/health` every 10 seconds and restarts the application if it stops answering.
- Policy: security-relevant logs are kept for at least 90 days, with access restricted to the technical team, and are reviewed when an alert or suspicious event appears. The retention configuration has not been verified in this execution and remains an operational follow-up.

8. Data retention and deletion (DPP §10)

- No buyer PII is stored, so the 90-day PII limit does not apply in practice.
- Tokens are deleted when the seller disconnects, and authorization states expire after 10 minutes.
- When a seller leaves, or Shopee asks, her Shopee data is deleted within 30 days, and we confirm the deletion in writing on request.

9. Infrastructure and operations

- Exposed ports: only 80/443 (web) and 22 (administration). Database and internal service ports are closed to the internet (checked from outside on 22 October 2026).
- Administration access is limited to the technical team, through individual accounts.
- Policy: two-factor authentication on the hosting, deployment and DNS/CDN panels; operating system and dependency updates applied regularly, with critical patches within 30 days; database backups kept outside the application server. The preparatory notes identify missing scheduled database

backups and other pending hardening; these policy commitments must be implemented and verified before being described as operational controls.
- Access policy: each person with access has an individual account (no shared logins); access is removed within 24 hours when no longer needed and reviewed once a year.

10. Incident response (DPP §9)

If any Shopee data may have been exposed we will contain the issue, rotate the Partner Key and encryption key if needed, revoke affected tokens, and notify Shopee at **ssrc@sea.com within 24 hours**, including what data was involved, what happened, the dates, the scope and the actions taken. A final report will follow after the investigation.

11. Penetration test

The Open Platform guide ("Requesting Access to Sensitive Data") requires a penetration test report for ISVs serving sellers in Thailand, Malaysia, Singapore and the Philippines, and for CNCB/HKCB ISVs, when they request sensitive data. Loja Pronta Prime serves sellers in **Brazil only** and **does not request buyer PII**, so that report is not a requirement for this app today.

No third-party penetration test has been run yet. We commit to running one with an accredited tester (black-box, external attack surface) before requesting any sensitive data, or when Shopee asks under DPP §8.4.

12. Declaration

For review and signature by the legal representative. Before signing, confirm the current Shopee Open Platform Terms of Service, Data Protection Policy and Platform Partner Rules, and verify the implementation and outstanding policy commitments described above. This unsigned draft does not record acceptance of those agreements.

Mentalidade Sem Limite Ltda — CNPJ 46.419.797/0001-67

Name: Guilherme Mendes Flauzino
Role: Administrator (legal representative)
Date: 22 October 2026
Signature: _____